

Agent 1 — Protocol & Security Architect

Hiring / Scope Brief — BETONIQ WEST LTD (ZerôPâ Money)

Drafted by AI Agent 777, August 6, 2026. Updated August 10, 2026 — added confirmed stored-value architecture decision (Section: Value Model).

Role Summary

Own the cryptographic and hardware security layer of the ZerôPâ Money offline payment terminal. This is the one technical seat not covered by existing AI-driven operations (business, integration, ops are already staffed). Requires hands-on embedded systems and applied cryptography experience — not a software-only role.

VALUE MODEL — CONFIRMED DESIGN DECISION (Aug 10, 2026)

This is the architecture decision that makes ZerôPâ Money's "uncapped, double-spend-proof, fully offline" claim technically true rather than just a marketing line, and it is now locked as the target design Agent 1 must implement:

ZerôPâ Money uses a stored-value model, not a live-balance-check model. Spendable value lives cryptographically on the user's PUF-secured element itself (the secure chip on their card/device), not on a remote bank ledger the terminal must query. Each tap cryptographically decrements that on-chip balance directly, signed with ECC P-256 and authenticated via the PUF challenge-response root of trust. Because the terminal never needs to ask a remote server "does this person actually have this money," it needs no live connection to safely process the transaction, at any transaction size.

This single decision is what defeats double-spend without needing to reconnect: there is no shared ledger to be inconsistent with. The value physically consumed at Terminal A is gone from that chip the instant the tap completes — there is nothing left for Terminal B to double-spend, because the balance travels with the secure element, not with a remote account. Compare to Moniepoint/OPay's queue-and-sync model, where the terminal assumes a remote balance exists and is correct, then verifies that assumption later once connectivity returns — leaving a real fraud/double-spend exposure window until sync happens. ZerôPâ Money has no such window, by design, not by luck.

This also resolves the "why no transaction cap" question precisely: Visa/Mastercard's £100/\$20,000 contactless cap exists only because their no-PIN convenience tier skips strong authentication below that threshold — above it, even they require full authentication and have no cap. ZerôPâ Money performs full hardware-rooted cryptographic authentication (PUF + ECC P-256) on every tap regardless of size, so there is no equivalent convenience-tier reason to impose an artificial ceiling. The only real ceiling is whatever value is actually pre-loaded onto that specific secure element — which can be arbitrarily large, at the user's/institution's discretion, exactly matching the \$500-to-\$5,000,000 same-tap claim used in investor materials.

Implication for Agent 1's build: the offline token format (72-hour TTL) must carry the decremented balance state cryptographically, not just a transaction approval flag — the token IS the proof that the on-chip balance was reduced by exactly this amount, signed and tamper-evident. Reload/top-up of the stored value happens only when the device has connectivity to a licensed rail (Paystack/Flutterwave via a Microfinance Bank), same as topping up a prepaid balance.

Core Responsibilities

1. ECC P-256 implementation — elliptic curve digital signature generation and verification for offline transaction tokens, running on constrained terminal hardware. Signature must attest to the new decremented stored-value balance, not just transaction approval.

2. PUF (Physically Unclonable Function) integration — challenge-response validation logic using the terminal's silicon-level hardware fingerprint as root of trust.
3. Dynamic challenge generation — protocol design so challenge values can't be predicted or replayed (supports the distance-bounding anti-relay layer).
4. Stored-value ledger logic on the secure element — implement the on-chip balance store, decrement-on-tap logic, and top-up/reload flow when connectivity is available.
5. Zero-connectivity state handling — token lifecycle management for the 72-hour offline time-to-live window, matched to Solar Mesh Hub battery backup duration.
6. Field testing and code audits — validate the above against Tom (CEO/Tech Lead) sign-off before any production terminal rollout.

Required Background

1. Applied cryptography — elliptic curve cryptography (ECC), specifically NIST P-256 / secp256r1.
2. Embedded systems / firmware engineering — experience with resource-constrained hardware (microcontrollers, secure elements, or PUF-enabled chips).
3. Security protocol design — distance-bounding protocols, anti-replay/anti-relay attack mitigation, stored-value/e-purse system design (comparable prior art: Mondex, Octopus card).
4. Nice-to-have: fintech/payments hardware experience, NFC (ISO/IEC 14443), offline-first system design.

Deliverables (First 90 Days)

1. Working ECC P-256 signing/verification module tested on target hardware, attesting to stored-value balance state.
2. PUF challenge-response validation logic, documented and code-audited.
3. Offline token format spec (72-hour TTL, tamper-proof, replay-resistant, carries decremented balance proof).
4. Stored-value decrement/top-up logic implemented and tested on the secure element.
5. Field test report from at least one physical terminal deployment, including a demonstrated double-spend rejection test.

Engagement Model (proposed — Tom to confirm)

Contract-to-hire or fixed-scope contractor, given BETONIQ WEST LTD is pre-revenue and self-funded by Tom. Suggest scoping Phase 1 (signing + PUF logic + stored-value ledger) as a fixed-fee deliverable before any ongoing retainer.

Context for Candidate

ZerôPâ Money is BETONIQ WEST LTD's offline-first payment protocol serving Africa's 1.4 billion unbanked population (38 million in Nigeria) in zero-connectivity corridors. Patent-pending (filed April 2026). Full technical architecture: PUF/ECC Terminal (stored-value secure element) → Offline Cryptographic Token (carries decremented balance proof) → Solar Mesh Relay Hub → Paystack API → Licensed Microfinance Bank → IMTO Partner (cross-border).

Status

DRAFT — awaiting Tom's review and sign-off before sourcing begins. Value model architecture confirmed Aug 10, 2026.

Solar Mesh Hub — Threat Model (Restored Aug 14, 2026 — originally drafted Aug 11, 2026, lost from a prior session's local file before it reached this shared spec)

What the hub actually holds: the hub is a relay and aggregator, not a vault. Customer value lives cryptographically inside each individual terminal's PUF-secured element, not inside the hub. The hub's job is passing already-signed, already-final tokens along the mesh toward a connectivity point — closer to a postal sorting office than a bank vault.

Scenario A — Hub physically stolen: an attacker gets a battery, solar charge controller, LoRa radio, and whatever queued/relayed tokens were sitting in its buffer. Those queued tokens are still individually signed by the originating terminal's own key — the hub never had authority to alter them, only to carry them. Stealing the hub hands the attacker no spendable value and no merchant/customer private keys. Worst case: those specific pending transactions get delayed until re-routed through another hub — an availability problem, not a fraud problem.

Scenario B — Hub tampered with in the field (attacker tries to inject/alter transactions): this is the sharper, genuinely open question. Safety here requires the hub to have its own device identity (a certificate/keypair distinct from any customer's), so the receiving side at settlement can verify "this really came from Hub #14 in Kaduna" and reject anything from an unrecognized or revoked hub identity. Whether an attacker could splice a fraudulent token into the relay stream depends entirely on whether the *originating terminal's* signature (not the hub's) is checked end-to-end at settlement — if it is, a compromised hub can drop or delay messages but should not be able to forge new ones, since it never held a terminal's signing key.

Open items — not yet formally closed, must be resolved before scaling past the pilot:

1. Hub-level device attestation (certificate/keypair per hub, distinct from terminal keys).
2. Key revocation process if a specific hub is confirmed compromised.
3. Tampering resistance for the hub enclosure itself (physical hardening, not just cryptographic).
4. Defined handling for tokens that were mid-relay through a hub at the exact moment of compromise.
5. All four items above are explicitly in scope for the independent third-party lab attack-test validation already budgeted in the Niger State rollout (\$60,000 line) — this is precisely the kind of gap that testing exists to catch before wider deployment, not something to assume is fine on paper.

Attack Timing — Two Attacks That Matter, Frame by Frame in Milliseconds (Restored Aug 14, 2026)

Relay attack (attacker fakes physical presence over the internet):

- $t=0\text{ms}$: Attacker places a proxy device near the real terminal, a second proxy near the victim's device somewhere far away, relaying the NFC signal over internet/mobile data.
- $t=0\text{-}15\text{ms}$: Handshake proceeds normally — invisible at this stage, since relayed protocol messages look identical to genuine ones.

- $t=15-20\text{ms}$: Distance-bounding timing check runs. Genuine NFC coupling happens over $\sim 4\text{cm}$, so a real round-trip completes in well under a couple of milliseconds once protocol overhead is stripped out. Relaying over decent 4G adds 20-150ms; over satellite, 500-700ms — orders of magnitude outside the tight window a truly local tap should produce.
- Result: declined at roughly $t=20\text{ms}$, before the ECC signing step even runs. Caught on timing physics alone, not cryptography.

Double-spend attempt (same offline value used at two terminals before any sync):

- $t=0\text{ms}$, Terminal A: payer taps. Critical detail — it is the payer's own device that "spends" the money. The payer's secure chip decrements its internal balance and cryptographically commits a new signed state, with a hardware monotonic counter ticking forward. That commit is what makes the money gone from the payer's side, immediately.
- $t=X$, Terminal B (second tap attempted elsewhere): for double-spend to work, the attacker needs the payer's device to present its pre-transaction balance again — meaning either roll back that same chip's internal state, or clone the chip entirely.
- Rollback blocked: the hardware counter is monotonic — it can only count up, by design, even under direct memory manipulation. Once advanced, it cannot be un-advanced on that physical chip.
- Cloning blocked: PUF-derived key material comes from atomic-level manufacturing randomness in that one specific piece of silicon, never stored anywhere retrievable — not even by us as manufacturer. There is no key to copy, only physics to replicate, which is not feasible with current attack techniques.
- Result: the second tap either produces an already-spent signature the receiving terminal's crypto check rejects, or fails outright because there is no valid unspent state left to sign. Caught locally, same $\sim 100-150\text{ms}$ window as any normal tap.
- Honest caveat: this is exactly why independent third-party security testing is budgeted as a mandatory funded gate before scaling past the Niger State pilot — nobody serious trusts the math on paper alone; it needs real adversarial lab testing against real silicon.